CAHIER DES CHARGES

Plateforme de menus numériques et commandes multi-cafés

Administration privée · Sites publics · Application serveur

Version 1.0 — 22 octobre 2026

Statut : spécification prête pour estimation et implémentation
Café exemple : **Café Atlas**, Casablanca — MAD

Document de spécification et de conception uniquement.
Aucune application n'est implémentée dans ce livrable.

Contrôle du document

Version	1.0
Date	22 octobre 2026
Objet	Spécification fonctionnelle, technique, données, UX, sécurité et acceptation
Identité d'exemple	Café Atlas ; Cappuccino Atlas, Thé à la menthe, Croissant amandes
Sources éditables	Ce document LaTeX et douze diagrammes PlantUML fournis avec les actifs

Convention de lecture

Confirmé reprend le besoin exprimé. **Recommandation** propose un choix cohérent mais réversible. **Hypothèse à valider** signale une décision métier non acquise. Les priorités sont P0 (MVP indispensable), P1 (important après stabilisation) et P2 (amélioration).

Table des matières

Contrôle du document i

1 Définition du projet 1

1.1 Vision, problème et objectifs . . . 1

1.2 Périmètre et terminologie . . . 1

1.3 MVP, limites et défauts proposés . . . 2

2 Rôles, permissions et comptes 3

2.1 Matrice d'autorisation . . . 3

2.2 Cycle des comptes et sessions . . . 3

3 Spécifications fonctionnelles 4

3.1 Administration privée . . . 4

3.2 Site public client . . . 4

3.3 Application mobile serveur . . . 5

3.4 Cycle canonique de commande . . . 6

4 Parcours et cas limites 7

4.1 Parcours complets . . . 7

4.1.1 Premier café et publication . . . 7

4.1.2 Première commande et traitement . . . 7

4.2 Réponses aux cas limites . . . 7

5 Diagrammes système et UML 9

5.1 Contexte et cas d'utilisation . . . 9

5.2 Domaine et séquences . . . 10

5.3 Activité, états, composants et déploiement . . . 16

6 Conception de la base de données 21

6.1 Principes et isolation . . . 21

6.2 Dictionnaire de données . . . 21

6.3 Intentions RLS et API publique sûre . . . 22

6.4 Désactivation, suppression et conservation 22

7 Architecture technique 23
7.1 Stack principale et arbitrages 23
7.2 Routage, environnements et images 23
7.3 Transaction, idempotence et concurrence 24
7.4 Realtime, push et reprise 24
7.5 Journalisation, sauvegarde et reprise 24

8 Sécurité, confidentialité et fiabilité 25
8.1 Contrôles obligatoires 25
8.2 Menaces prioritaires 25

9 UX, information et écrans 26
9.1 Architectures de navigation 26
9.2 Inventaire détaillé des écrans 26
9.3 Wireframes annotés 28
9.4 Libellés et états 29

10 Design system visuel 30
10.1 Direction et couleurs 30
10.2 Typographie, espace et grille 30
10.3 Accessibilité, mouvement et composants 31

11 Mockups représentatifs 32

12 Tests et acceptation 35
12.1 Stratégie de vérification 35
12.2 Scénarios Given / When / Then 35
12.3 Checklist de sortie MVP 36

13 Feuille de route de livraison 37

14 Traçabilité et revue finale 38
14.1 Décisions restantes nécessitant validation 38

A Registre des sources et actifs 39

Table des figures

5.1 Contexte système et services externes . . . 9
5.2 Cas d'utilisation UML des trois acteurs . . . 10
5.3 Diagramme de classes UML du domaine . . . 11
5.4 Séquence UML de création et publication . . . 12
5.5 Séquence UML de soumission client . . . 13
5.6 Séquence UML Realtime et push . . . 14
5.7 Séquence UML de concurrence entre deux serveurs . . . 15
5.8 Activité UML du parcours de commande . . . 16
5.9 Machine à états UML de la commande . . . 17
5.10 Diagramme UML des composants . . . 18
5.11 Diagramme UML de déploiement . . . 19
5.12 Diagramme entité–association de la base . . . 20

9.1 Wireframe annoté A05 — gestion du menu . . . 28
9.2 Wireframe C01–C04 — menu et panier . . . 28
9.3 Wireframe S02–S04 — traitement serveur . . . 29

11.1 Mockup haute fidélité — administration du menu Café Atlas . . . 32
11.2 Mockup haute fidélité — menu public mobile, Table 07 . . . 33
11.3 Mockup haute fidélité — commandes actives du serveur . . . 34

Liste des tableaux

1.1 Terminologie du produit 1

2.1 Permissions par rôle 3

3.1 Exigences de l'administration 4
3.2 Exigences du site public 5
3.3 Exigences de l'application serveur 5
3.4 Transitions autorisées 6

4.1 Cas limites et comportement attendu 7

6.1 Dictionnaire de données conceptuel 21
6.2 Intentions des politiques RLS 22

7.1 Architecture recommandée 23

8.1 Menaces et vérifications 25

9.1 Écrans de l'administration 26
9.2 Écrans du client public 27
9.3 Écrans de l'application serveur 27

10.1 Tokens de couleur 30
10.3 Catalogue de composants 31

12.1 Scénarios d'acceptation critiques 35

13.1 Jalons, dépendances et risques 37

14.1 Traçabilité des besoins majeurs 38

Chapitre 1

Définition du projet

1.1 Vision, problème et objectifs

La plateforme permet à un administrateur unique de créer et exploiter plusieurs sites de menus numériques depuis une application privée, sans dupliquer le code ni déployer une application par café. Chaque établissement possède une marque, une URL, un menu, des tables, des serveurs et des commandes isolés, tout en partageant un modèle de site et un projet Supabase.

Les objectifs métier sont : réduire la mise en ligne d'un café à une configuration sans code ; permettre une commande à table sans compte ni installation ; transmettre rapidement les commandes au personnel du bon café ; empêcher tout accès croisé ; maintenir une solution exploitable par une personne seule ou une petite équipe.

Les indicateurs proposés sont le taux de commandes soumises, le délai médian création–acceptation, le taux d'échec push, le taux de doublons empêchés, la disponibilité du parcours public et le temps d'affichage du menu mobile. Ils sont des recommandations et non des objectifs chiffrés confirmés.

1.2 Périmètre et terminologie

Table 1.1 – Terminologie du produit

Terme	Définition
Plateforme	Administration, sites publics, application serveur et backend partagés.
Café	Tenant logique isolant marque, menu, tables, personnel et commandes.
Publication	Instant où une version cohérente du menu et de la marque devient publique.
Table	Point de commande physique, avec libellé et jeton QR opaque.
Client public	Visiteur anonyme ; aucun compte Supabase Auth.
Serveur	Employé authentifié, affecté exactement à un café actif dans le MVP.
Jeton de suivi	Secret aléatoire lié à une commande et jamais listable publiquement.

Exigence confirmée

Trois interfaces distinctes ; un seul projet Supabase ; un modèle public réutilisable ; un administrateur unique ; aucune authentification client ; aucune permission de menu ou de plateforme pour les serveurs.

Recommandation

Next.js pour les deux interfaces web, React Native/Expo pour une application Android et iOS partagée, et Supabase Edge Functions pour toutes les mutations anonymes ou privilégiées.

1.3 MVP, limites et défauts proposés

Le MVP inclut création et cycle de vie des cafés, personnalisation guidée, menu et publication, tables/QR, comptes serveurs, panier anonyme, commande et suivi, traitement temps réel, notifications push, historique, journal minimal et supervision centrale.

Sont explicitement exclus : marketplace, constructeur glisser-déposer, portail propriétaire, inscription autonome, second modèle public, paiement, livraison, réservation, abonnement, fidélité, POS, gestion de stock, pourboires, division de note et analytics avancés.

Hypothèse à valider

Un QR par table encode `https://menu.domaine.tld/cafe-atlas?table=JETON`. L'URL générale permet de consulter et remplir le panier, mais désactive l'envoi avec « Scannez le QR de votre table pour commander ». Aucune saisie libre du numéro de table.

Autres défauts à valider : devise unique par café (MAD pour Café Atlas) ; publication explicite des brouillons ; disponibilité produit immédiatement effective ; annulation par serveur avant `servie` avec motif ; conservation des commandes 24 mois et audits 12 mois.

Chapitre 2

Rôles, permissions et comptes

2.1 Matrice d'autorisation

Table 2.1 – Permissions par rôle

Ressource/action	Admin	Serveur	Public
Créer, modifier, activer un café	Oui	Non	Non
Modifier marque, menu et tables	Oui	Non	Non
Publier le site	Oui	Non	Non
Gérer les comptes serveurs	Oui	Non	Non
Voir toutes les commandes	Oui	Non	Non
Voir les commandes de son café	Oui	Oui	Non
Changer un statut permis	Oui (support)	Oui	Non
Lire un menu publié actif	Oui	Oui	Oui
Créer une commande via le parcours	Non	Non	Oui
Suivre une commande	Oui	Oui, même café	Oui, jeton exact
Enregistrer son appareil push	Non	Oui, pour soi	Non

La défense est triple : l'interface ne présente pas l'action interdite, le serveur vérifie identité et rôle, et PostgreSQL/RLS limite les lignes. L'URL, le slug, un champ `cafe_id` client et la clé Supabase `anon` ne sont jamais des preuves d'autorisation.

2.2 Cycle des comptes et sessions

L'administrateur est provisionné hors parcours public avec un rôle `platform_admin` ; le MFA est recommandé. Il invite le serveur par email et l'affecte à un café. Une fonction privilégiée, seule détentrice de la clé de service, crée l'identité Auth. Le serveur choisit son mot de passe via un lien temporaire et le reset suit le flux Auth standard.

La désactivation révoque toutes les sessions, met le profil inactif et désactive ses jetons push. Chaque reprise d'application revalide profil et café. Les jetons d'accès sont courts, les refresh tokens tournent et une réinitialisation sensible permet la révocation globale.

Chapitre 3

Spécifications fonctionnelles

3.1 Administration privée

Table 3.1 – Exigences de l'administration

ID	Pri.	Description et règles	Acceptation testable
ADM-001	P0	Connexion administrateur ; aucun écran métier sans rôle actif.	Non authentifié redirigé ; serveur 403 ; session révoquée refusée.
ADM-002	P0	Tableau central : cafés, état, URL, commandes actives, publication.	Recherche, filtres et compteurs exacts.
ADM-003	P0	Assistant café : identité, slug, contacts, devise, marque.	Slug unique ; brouillon non public ; aucun code/déploiement dédié.
ADM-004	P0	Nom, logo, couleurs, description et contacts avec aperçu.	Validation, responsive et contraste corrigé/refusé.
ADM-005	P0	Catégories : créer, renommer, activer, ordonner.	Ordre persistant ; inactif absent ; suppression avec produits bloquée.
ADM-006	P0	Produits : photo, texte, prix, disponibilité, catégorie, ordre.	Prix en unités mineures ; upload contrôlé ; indisponibilité immédiate.
ADM-007	P0	Aperçu du brouillon et publication atomique.	Tout ou rien ; cache invalidé ; date/auteur/version enregistrés.
ADM-008	P0	Tables et QR individuels téléchargeables.	Jeton opaque ; PNG/PDF ; désactivation et rotation invalidantes.
ADM-009	P0	Inviter, affecter, désactiver, réinitialiser un serveur.	Un café au MVP ; aucun droit admin/menu ; révocation de session.
ADM-010	P0	Commandes centrales filtrées par café, statut, date, table.	Lignes figées, total, notes, chronologie et pagination serveur.
ADM-011	P0	Suspendre/réactiver avec confirmation et motif.	Nouvelles commandes refusées ; commandes existantes traitables.
ADM-012	P1	Audit publication, suspension, comptes, QR et corrections.	Acteur, café, action, cible, date, sans secret.

3.2 Site public client

Table 3.2 – Exigences du site public

ID	Pri.	Description et règles	Acceptation testable
PUB-001	P0	Résoudre un café actif et sa version publiée par slug.	Brouillon, suspendu ou inconnu ne divulguent rien de privé.
PUB-002	P0	Catégories et produits : photo, description, prix, disponibilité.	Navigation ancrée, devise cohérente, indisponible non ajoutable.
PUB-003	P0	Panier local par café : quantité, suppression, notes.	Quantité 1–20 ; paniers non fusionnés ; persistance après refresh.
PUB-004	P0	Vérifier le contexte table avant l'envoi.	Jeton associé au café ; URL générale consultable mais bloquée.
PUB-005	P0	Soumission anonyme avec idempotence.	Prix/disponibilité/total recalculés ; double clic = une commande.
PUB-006	P0	Divergence de panier.	Indisponible signalé ; nouveau prix confirmé avant nouvel envoi.
PUB-007	P0	Confirmation et suivi secret sans compte.	Référence + jeton ; aucune lecture sans jeton ; chronologie à jour.
PUB-008	P0	Reprise après interruption réseau.	Même clé au retry ; commande existante retournée si déjà commitée.
PUB-009	P1	Performance et WCAG 2.2 AA sur mobile.	Clavier, cible 44 px, images adaptées, squelette stable.

3.3 Application mobile serveur

Table 3.3 – Exigences de l'application serveur

ID	Pri.	Description et règles	Acceptation testable
SRV-001	P0	Email/mot de passe et résolution serveur du profil/café.	Compte ou café inactif refusé ; aucune sélection du café.
SRV-002	P0	Commandes du seul café en temps réel.	RLS + filtre ; reconnexion avec resynchronisation canonique.
SRV-003	P0	Liste active : nouvelles puis ancienneté.	Table, âge, total, statut et notes immédiatement lisibles.
SRV-004	P0	Détail : lignes, quantités, notes, total, heure, historique.	Instantanés historiques, pas les produits actuels.
SRV-005	P0	Accepter et avancer selon la machine d'états.	Update atomique/version ; conflit 409, refresh et message.
SRV-006	P0	Historique filtrable et paginé.	Seulement son café ; terminaux `servie/annulee`.
SRV-007	P0	Push en arrière-plan/fermé.	Permission expliquée ; contenu verrouillé générique ; deep link contrôlé.
SRV-008	P0	Doublons, événements manqués et réseau.	Déduplication id+version ; reprise canonique ; actions offline bloquées.
SRV-009	P0	Compte, notifications, son et déconnexion.	Jeton push désactivé ; permission OS fidèle ; lien réglages.
SRV-010	P1	Android et iOS.	Recommandation, matrice OS/appareils documentée.

3.4 Cycle canonique de commande

Les seuls états sont `nouvelle`, `acceptee`, `en_preparation`, `prete`, `servie` et `annulee`. Aucun retour arrière au MVP.

Table 3.4 – Transitions autorisées

Depuis	Vers	Acteur	Règle
Création	`nouvelle`	Client/fonction	Café et table actifs, transaction valide.
`nouvelle`	`acceptee`	Serveur/admin	Premier acteur gagnant enregistré.
`acceptee`	`en_preparation`	Serveur/admin	Transition explicite.
`en_preparation`	`prete`	Serveur/admin	Transition explicite.
`prete`	`servie`	Serveur/admin	État terminal.
Non terminal	`annulee`	Serveur/admin	Motif obligatoire, terminal.

Chaque mutation exige la version lue. PostgreSQL met à jour uniquement si elle est courante, incrémente la version et insère l'historique dans la même transaction.

Chapitre 4

Parcours et cas limites

4.1 Parcours complets

4.1.1 Premier café et publication

L'administrateur crée « Café Atlas » et le slug `cafe-atlas`, ajoute contacts, logo et couleur `#8B5E3C`, crée les catégories Cafés, Thés et Pâtisseries, puis les produits d'exemple. Il crée T01–T12, télécharge les QR, corrige les éléments bloquants de l'aperçu et publie. Une modification suivante reste en brouillon, sauf la disponibilité produit, immédiate.

4.1.2 Première commande et traitement

Le client scanne T07, ajoute Cappuccino Atlas (32,00 MAD) et Croissant amandes (24,00 MAD), note « sans cannelle » et envoie. Le serveur recalcule 56,00 MAD, crée AT-1042 et remet un jeton secret. Le serveur reçoit Realtime si l'app est ouverte, sinon le push, accepte puis progresse jusqu'à `servie`. Le client voit chaque état dans le suivi.

4.2 Réponses aux cas limites

Table 4.1 – Cas limites et comportement attendu

Situation	Comportement obligatoire
Produit devenu indisponible	Refuser les lignes concernées, conserver et rendre corrigeable le panier.
Prix changé	Réponse `PRICE_CHANGED`, ancien/nouveau prix et nouveau total ; reconfirmation.
Café suspendu	Nouvelles commandes refusées ; suivi et clôture des existantes conservés.
Coupure pendant l'envoi	Retry avec la même clé ; résultat existant retourné après commit perdu.
Soumission répétée	Contrainte unique café+clé ; exactement une commande.
Deux serveurs	Premier update gagne ; second reçoit 409, recharge et n'écrit pas d'histoire.

Situation	Comportement obligatoire
Push échoué	Realtime si actif ; sinon découverte par resynchronisation ; jeton invalide désactivé.
QR invalide	Message explicite, menu général éventuel, envoi impossible.
Suivi rouvert	Jeton local/URL sûre ; une seule commande ; référence seule insuffisante.
Realtime coupé	Bandeau, backoff exponentiel avec jitter, resynchronisation complète à la reprise.

Chapitre 5

Diagrammes système et UML

Tous les diagrammes sont rendus à partir de sources PlantUML éditables. Ils reprennent les trois acteurs, l'isolation par café et les six états canoniques.

5.1 Contexte et cas d'utilisation

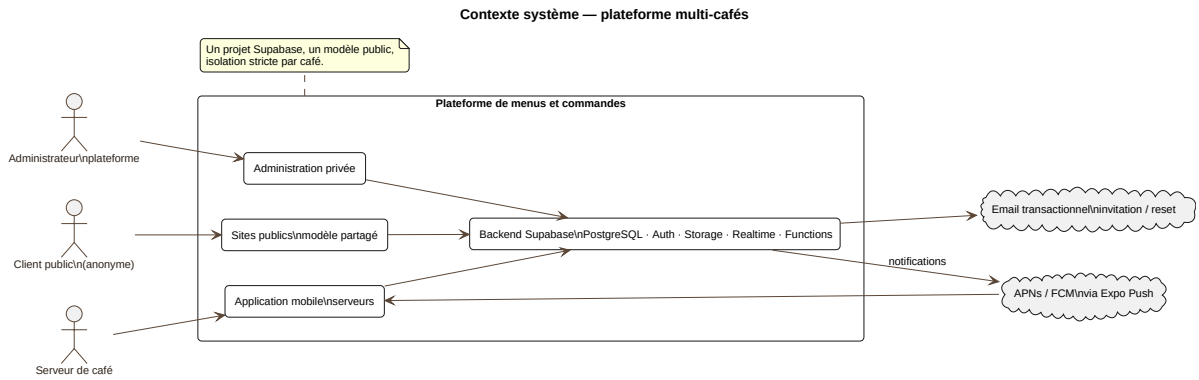


Figure 5.1 – Contexte système et services externes

La figure 5.1 fixe les frontières : le public n'accède qu'au site et aux fonctions limitées ; les identités admin/serveur utilisent Auth ; le push est distinct de Realtime.

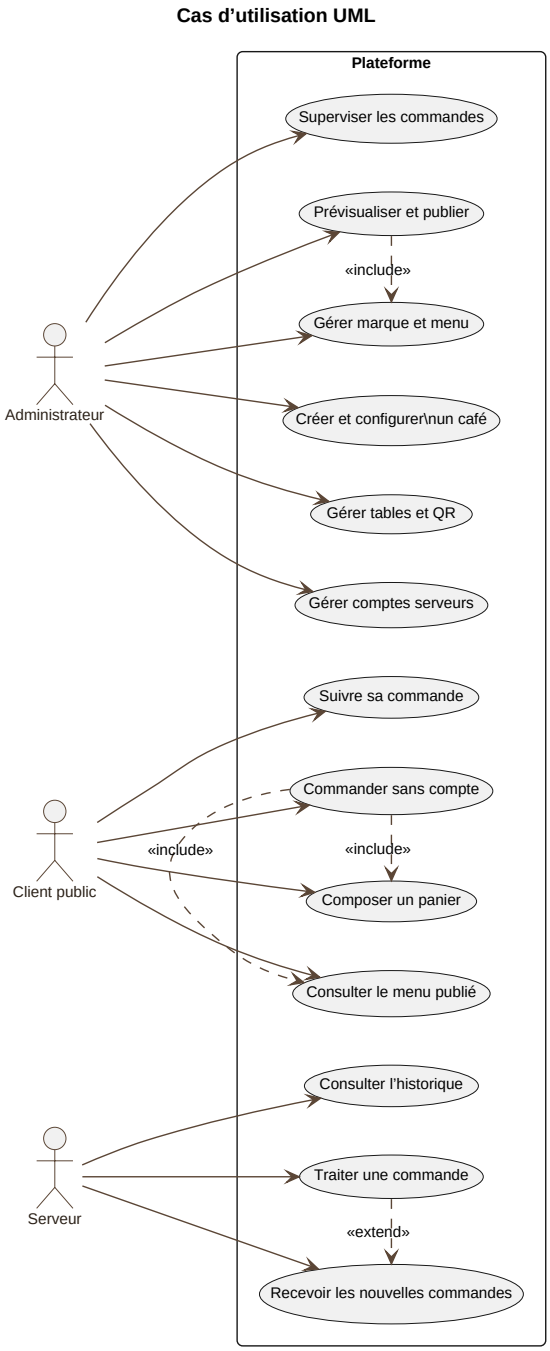


Figure 5.2 – Cas d'utilisation UML des trois acteurs

La figure 5.2 montre que seul l'administrateur configure et publie, tandis que le client commande sans compte et le serveur traite seulement les commandes de son café.

5.2 Domaine et séquences

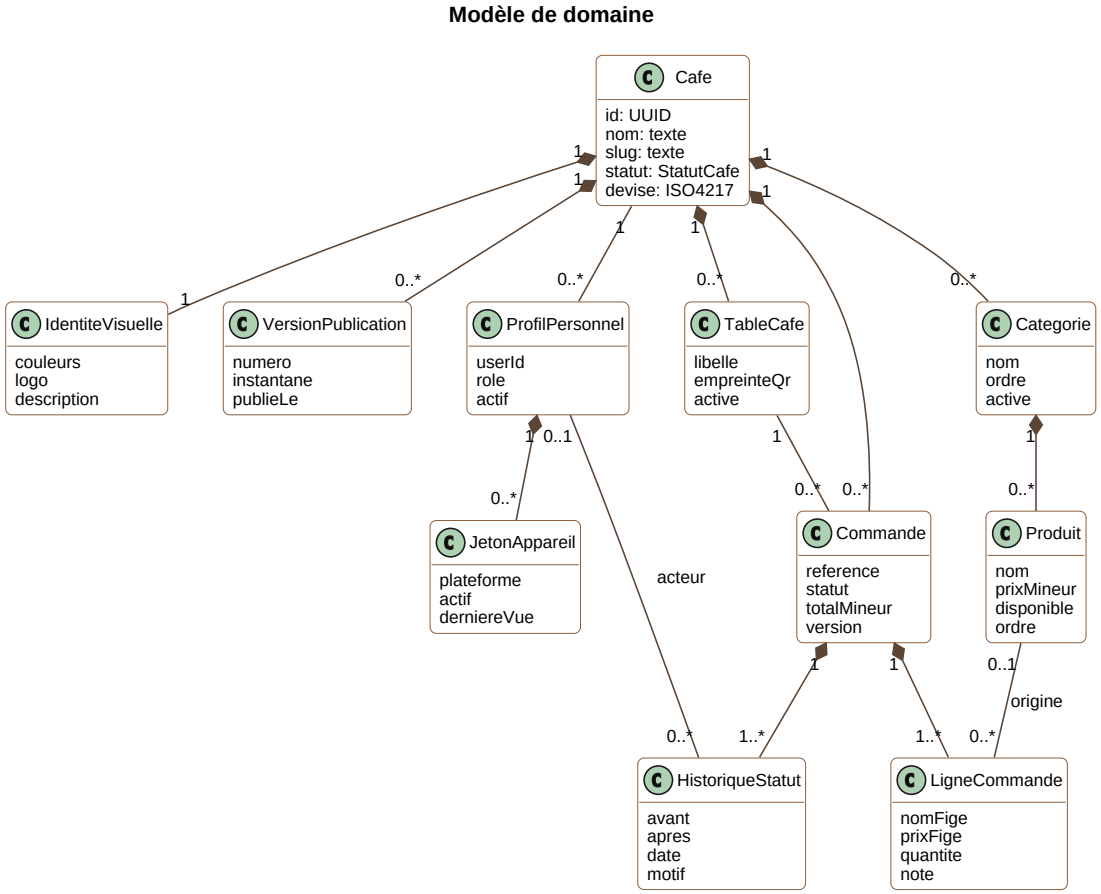


Figure 5.3 – Diagramme de classes UML du domaine

Les compositions de la figure 5.3 expriment la propriété tenant. Une ligne conserve éventuellement le lien produit, mais ses valeurs historiques sont figées.

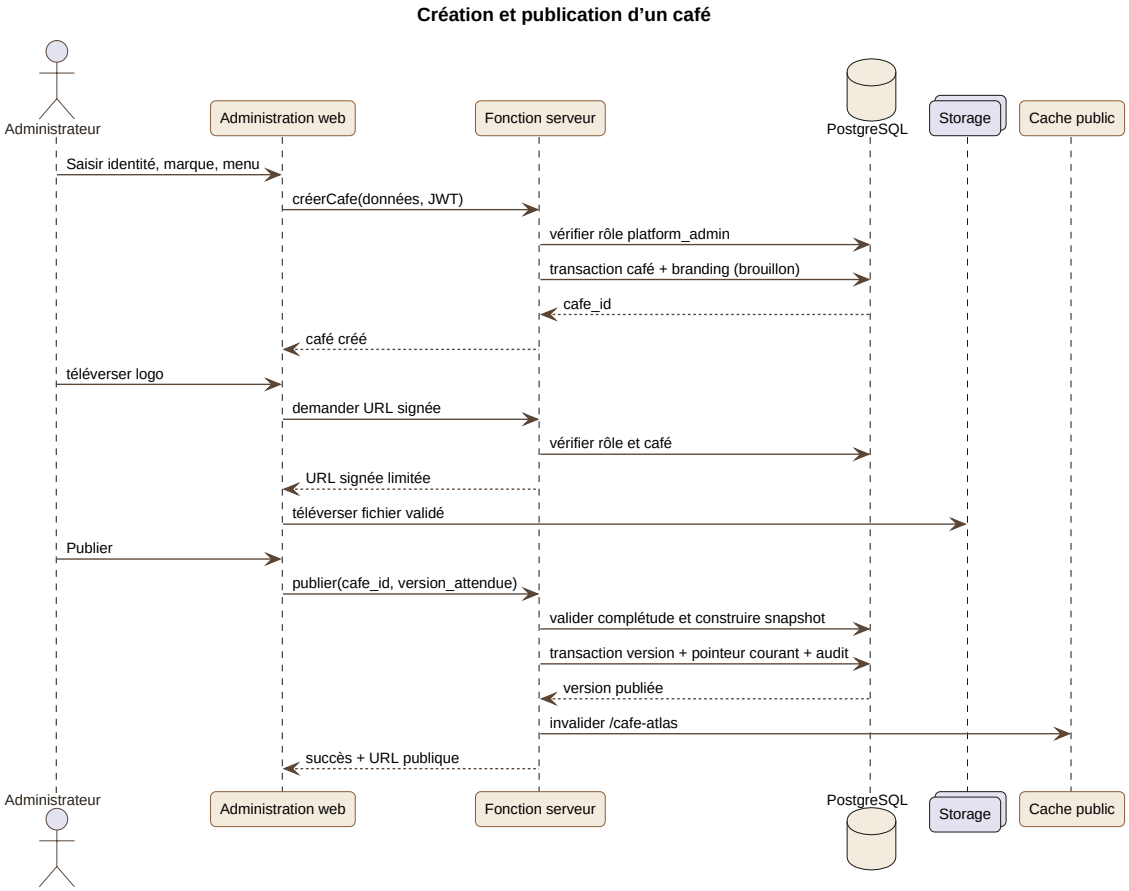


Figure 5.4 – Séquence UML de création et publication

La publication vérifie le rôle, crée un snapshot atomique et invalide le cache après succès.

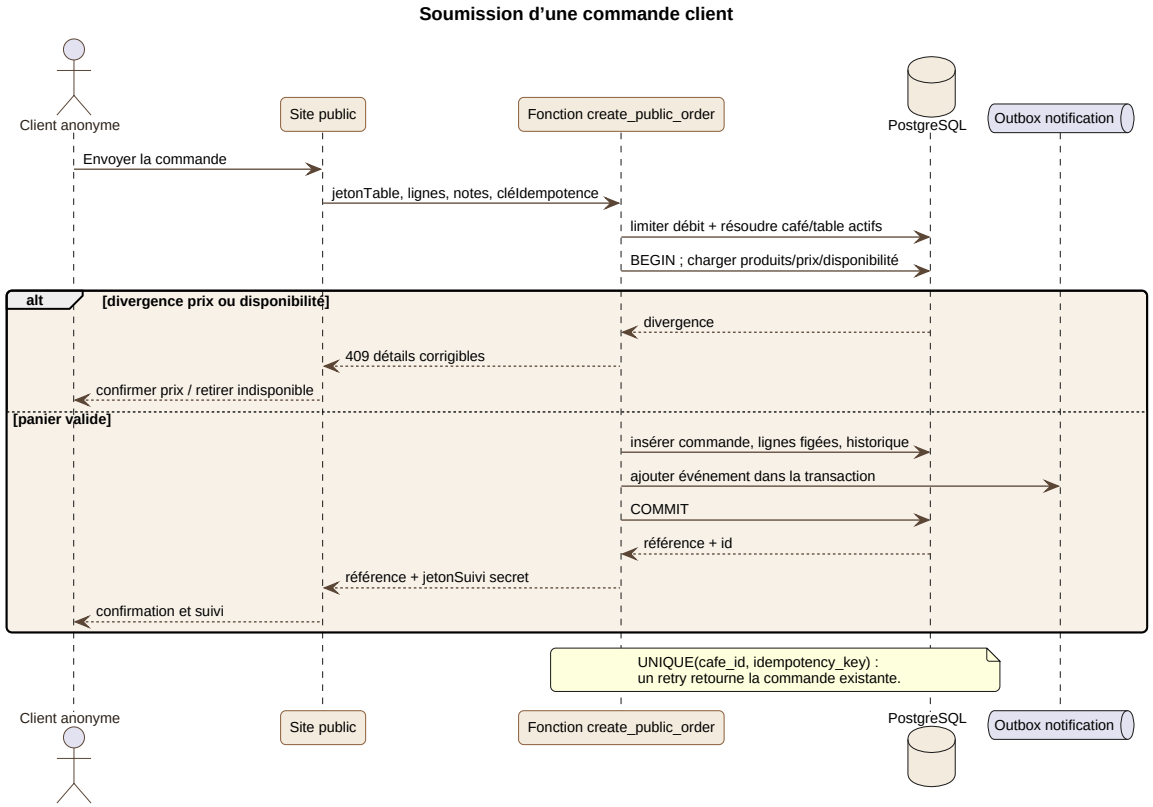


Figure 5.5 – Séquence UML de soumission client

La figure 5.5 place validation, instantanés et événement d'outbox dans la même transaction et rend la clé d'idempotence explicite.

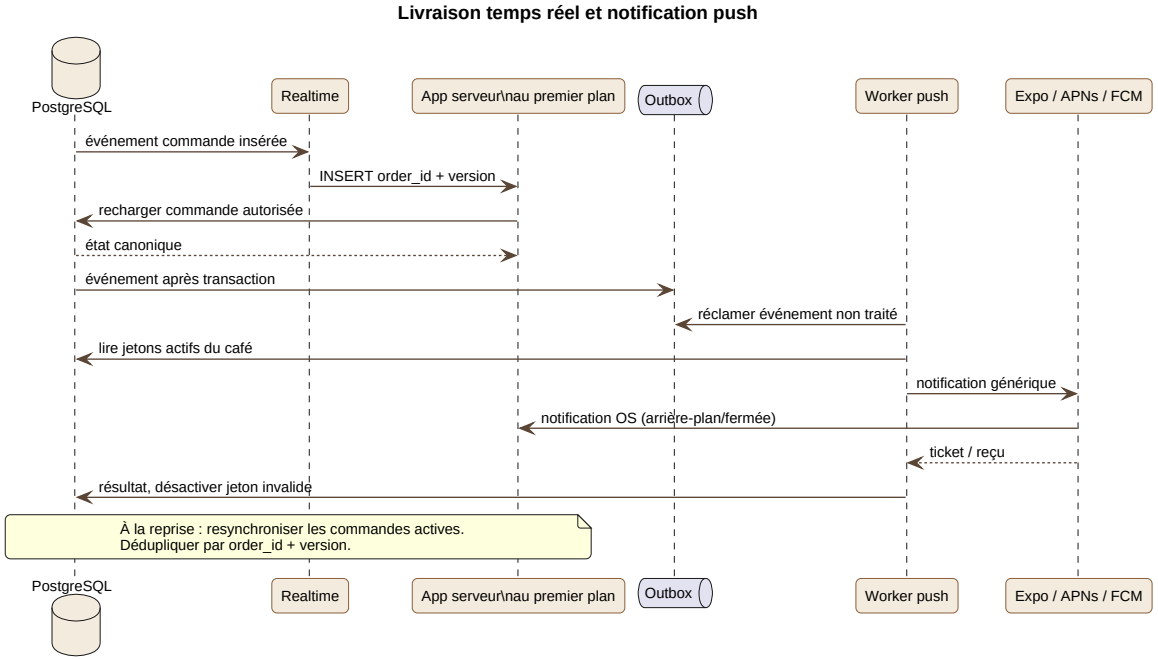


Figure 5.6 – Séquence UML Realtime et push

Realtime sert l'app au premier plan ; l'outbox et Expo/APNs/FCM prennent en charge l'arrière-plan ou l'application fermée. Une reprise recharge toujours l'état canonique.

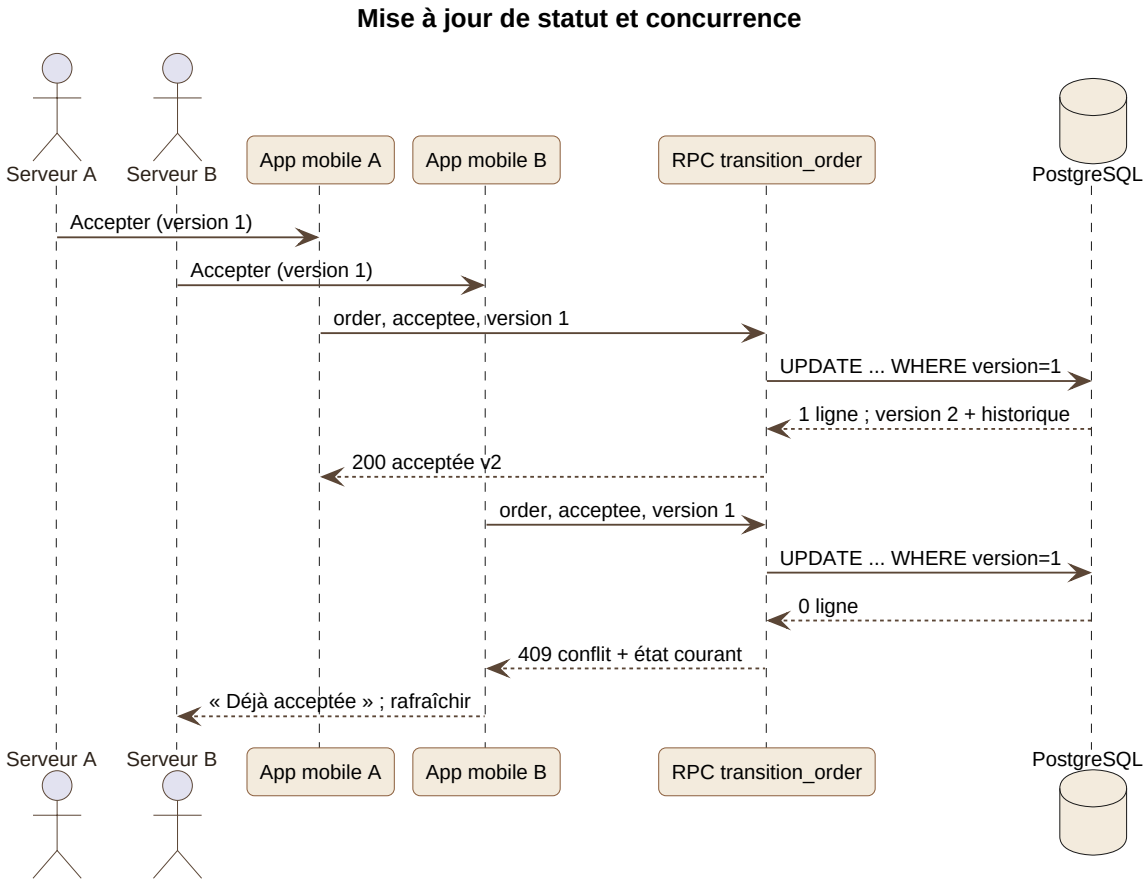


Figure 5.7 – Séquence UML de concurrence entre deux serveurs

La version optimiste permet à une seule transition de gagner et rend le conflit récupérable.

5.3 Activité, états, composants et déploiement

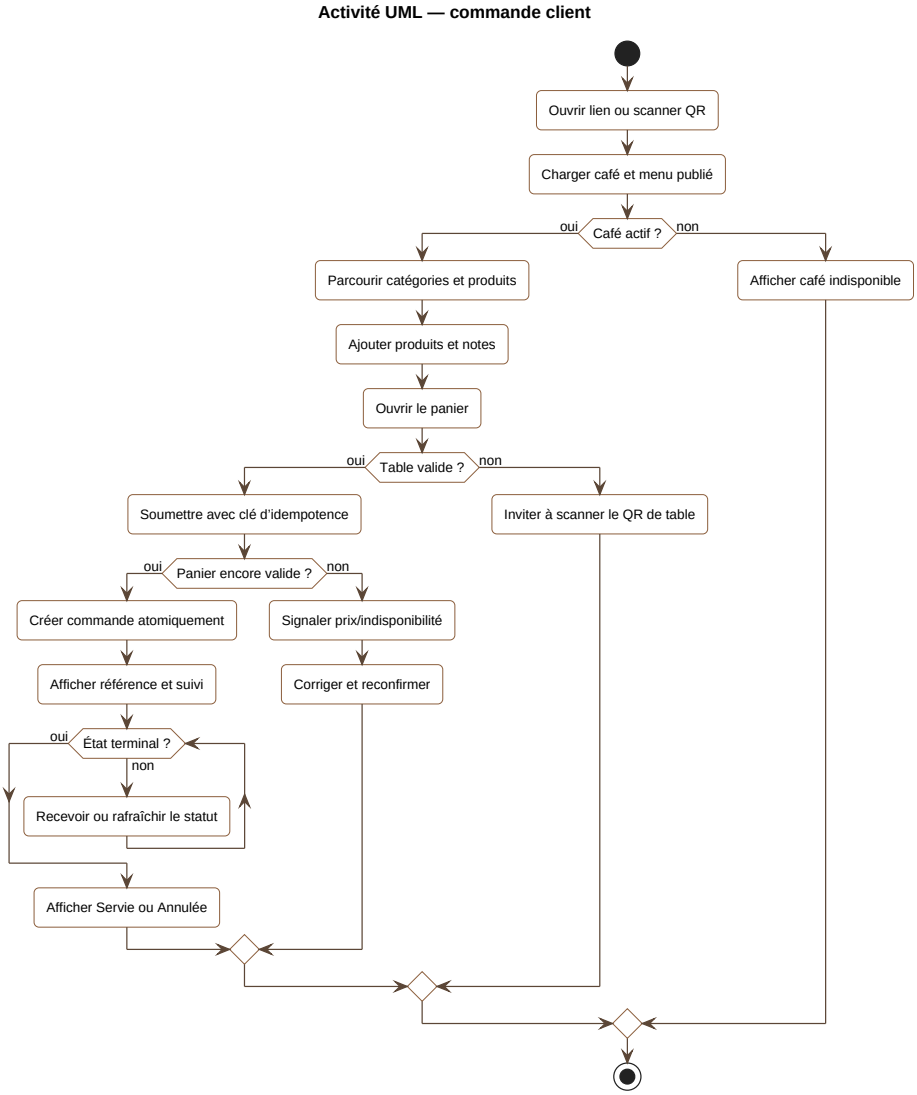


Figure 5.8 – Activité UML du parcours de commande

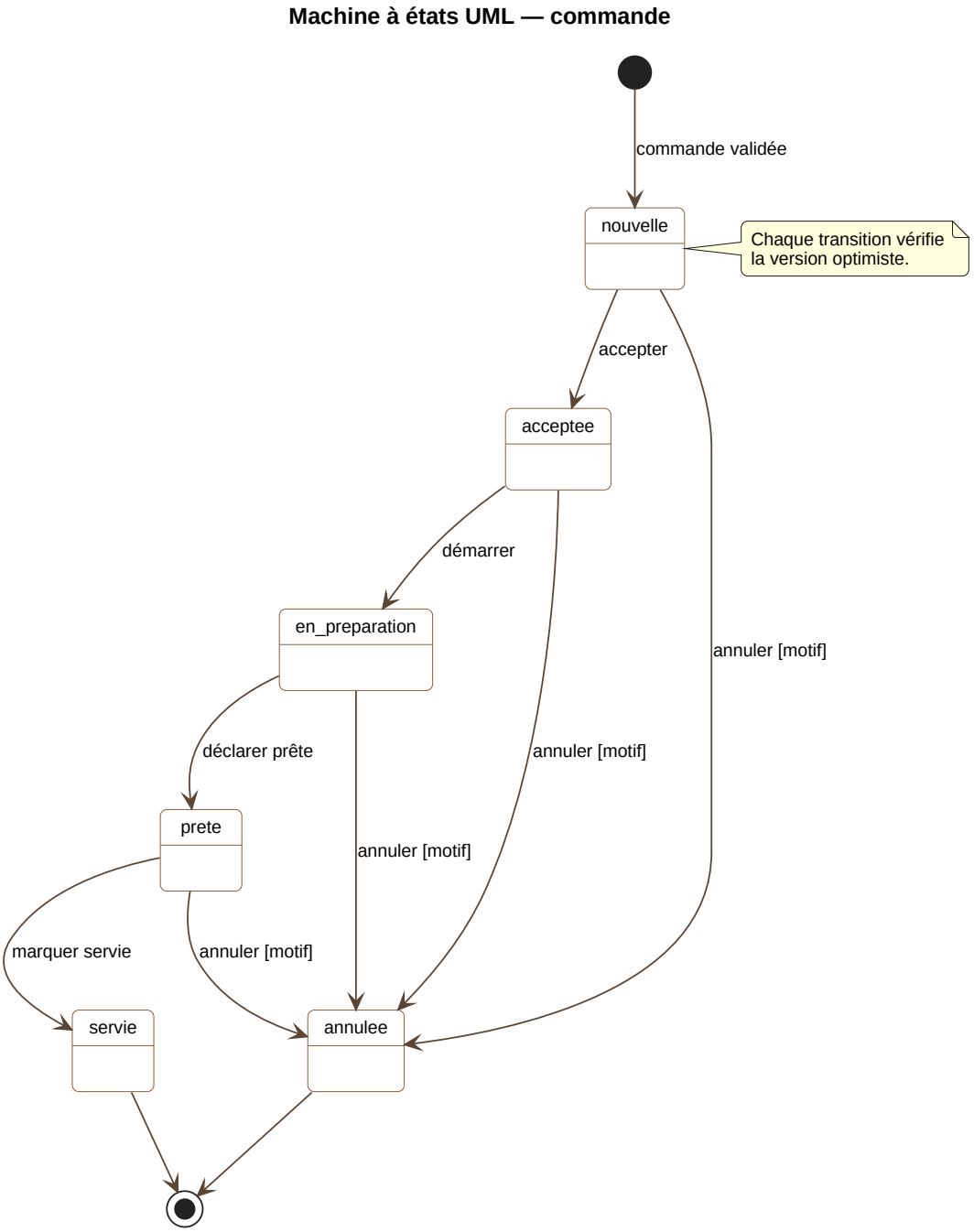


Figure 5.9 – Machine à états UML de la commande

La figure 5.9 est normative : aucune autre transition ne doit être codée dans l'UI, les fonctions ou PostgreSQL.

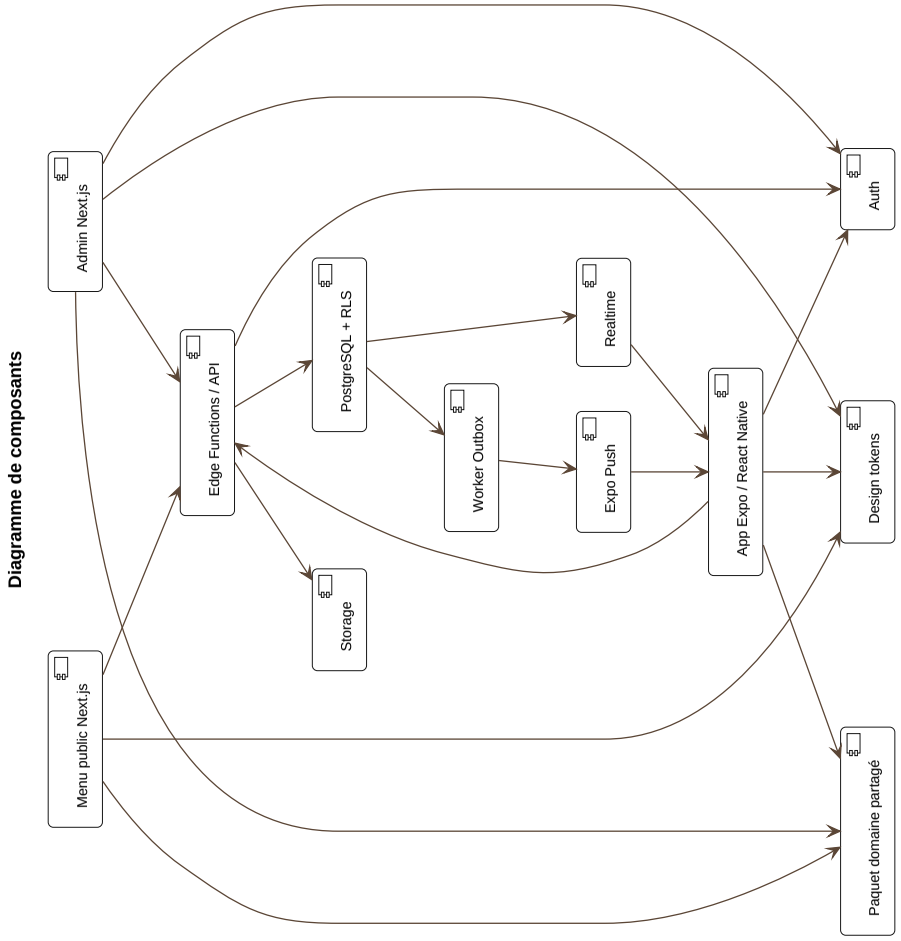


Figure 5.10 – Diagramme UML des composants

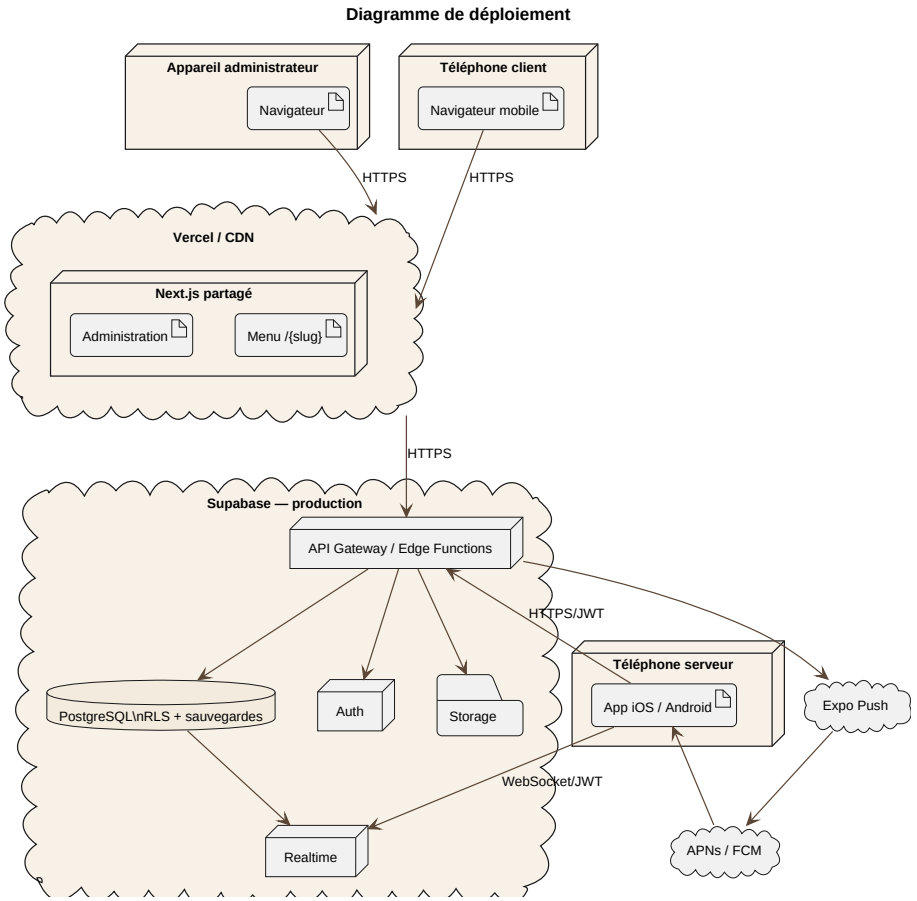


Figure 5.11 – Diagramme UML de déploiement

Le déploiement reste partagé : un Next.js, une application mobile, un projet Supabase par environnement et une chaîne push commune.

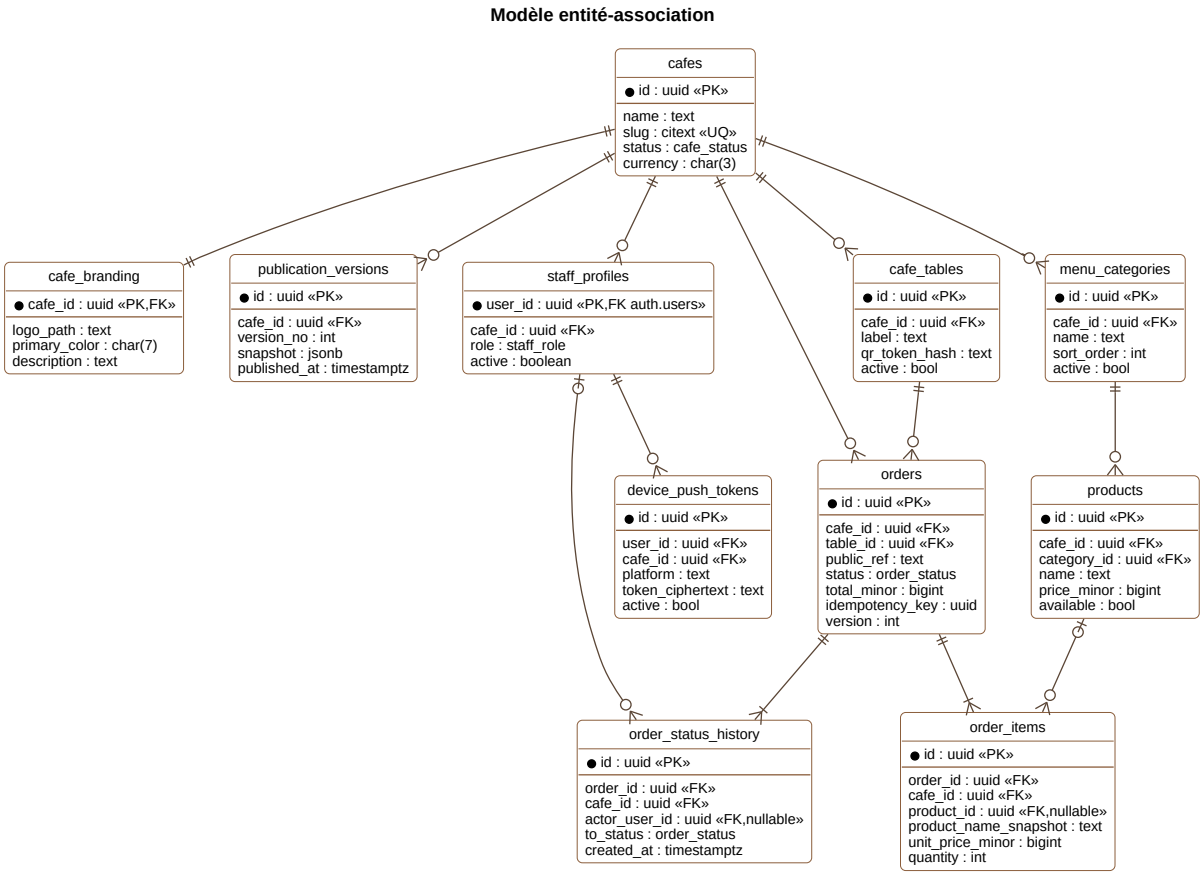


Figure 5.12 – Diagramme entité–association de la base

Chapitre 6

Conception de la base de données

6.1 Principes et isolation

Toutes les données tenant portent un `cafe_id` UUID non nul. Les contraintes composites empêchent d'associer un produit, une catégorie, une table ou une commande de cafés différents. Les montants sont des entiers d'unités mineures (3200 pour 32,00 MAD) accompagnés d'une devise ISO 4217 figée dans la commande. Les dates sont en `timestamptz` UTC et rendues dans le fuseau du café.

Les noms, prix unitaires, options et calculs de ligne sont copiés dans `order_items` ; une modification ou suppression logique du catalogue n'altère jamais l'historique.

6.2 Dictionnaire de données

Table 6.1 – Dictionnaire de données conceptuel

Table	Champs essentiels	Contraintes et index
`cafes`	id UUID PK, name, slug, status, currency, timezone, contacts, dates	slug unique ; index status ; formats contacts.
`cafe_branding`	cafe_id PK/FK, logo_path, primary/accent color, description	HEX valide ; chemin Storage contrôlé.
`publication_versions`	id, cafe_id, version_no, snapshot JSONB, published_at/by	unique café+version ; pointeur courant.
`staff_profiles`	user_id PK vers Auth, cafe_id, role, active, display_name	admin sans café ; serveur avec café ; index actif.
`menu_categories`	id, cafe_id, name, sort_order, active, dates	unique composite ; index actif+ordre.
`products`	id, cafe/category IDs, name, description, price_minor, photo, flags, ordre	FK même café ; prix positif ; index menu.
`cafe_tables`	id, cafe_id, label, qr_token_hash, active, rotated_at	libellé unique/café ; hash QR global unique.
`orders`	id, cafe/table IDs, public_ref, tracking hash, status, currency, total, note, idempotency, version, dates	unique café+idempotence et café+référence ; index actifs.
`order_items`	id, order/cafe/product IDs, nom/prix figés, quantité, total, note	quantité 1–20 ; cohérence ligne et café.
`order_status_history`	id, order/cafe IDs, avant/après, acteur, motif, date, version	index commande+date ; version unique/commande.
`device_push_tokens`	id, user/cafe IDs, platform, token chiffré, active, last_seen, failures	jeton unique ; index actifs ; purge.

Table	Champs essentiels	Contraintes et index
`audit_events`	id, cafe/acteur, action, type/id cible, metadata, date	append-only ; index acteur/café/date ; pas de secrets.

Le snapshot public est immuable et dénormalisé. Une vue publique contrôlée peut joindre la disponibilité courante afin que l'arrêt de vente soit immédiat sans republier.

6.3 Intentions RLS et API publique sûre

Table 6.2 – Intentions des politiques RLS

Acteur	Lecture	Écriture
Public anon	Vue/RPC du menu publié actif ; suivi d'une seule commande par jeton.	Aucune écriture directe ; fonction limitée, validée et rate-limitée.
Serveur Auth	Profil propre, café affecté, commandes/lignes/histoire de ce café.	RPC de transition ; jetons push propres ; jamais menu/branding.
Administrateur	Toutes données après rôle vérifié.	Fonctions admin et Auth via backend privilégié.
Service role	Fonctions serveur uniquement.	Jamais exposé aux bundles web/mobile.

Les politiques dérivent le café de `auth.uid()` et du profil, pas d'un champ client. Les fonctions `security definer` fixent le `search_path`, qualifient les schémas et limitent `EXECUTE`. Les jetons de table et de suivi sont aléatoires, transmis une fois et stockés hachés.

6.4 Désactivation, suppression et conservation

Suspendre conserve les données. Archiver produit/table préserve les références. Supprimer un café est une opération hors UI, précédée d'un export et d'un délai. Les actifs orphelins sont purgés après délai ; les push tokens sont chiffrés. Les audits évitent notes, emails complets et secrets. Les périodes proposées restent à valider juridiquement.

Chapitre 7

Architecture technique

7.1 Stack principale et arbitrages

Table 7.1 – Architecture recommandée

Couche	Choix	Motivation et compromis
Monorepo	pnpm + Turborepo	Types, validation et tokens partagés, exploitation légère.
Web	Next.js + TypeScript	Admin et public, routage slug, SSR/ISR et invalidation.
Mobile	Expo/React Native	Base Android/iOS commune ; dépendance Expo Push assumée.
Backend	Supabase	PostgreSQL, Auth, Storage, Realtime, Edge Functions imposés.
Validation	Zod + SQL	Retour UX homogène ; base comme autorité finale.
Hébergement	Vercel, Supabase, EAS	Faible charge opérationnelle ; fournisseurs remplaçables.
Observabilité	Sentry + logs structurés	Corrélation par request ID, données sensibles expurgées.

Organisation proposée : `apps/admin-web`, `apps/public-menu`, `apps/waiter-mobile`, `packages/domain`, `packages/ui-web`, `packages/design`, `supabase/functions`, `supabase/contracts` et `docs`. Le domaine partagé contient types et machine d'états, jamais de secret.

7.2 Routage, environnements et images

Le MVP emploie `admin.domaine.tld` et `menu.domaine.tld/{slug}`. Les domaines personnalisés sont P2. Dev, staging et production ont chacun leur projet Supabase et leurs secrets. Seuls URL Supabase et clé `anon` sont publics ; service role, push et monitoring restent dans les coffres fournisseurs.

Les buckets publics de lecture sont séparés pour marque et produits. Toute écriture exige une URL signée obtenue après contrôle de rôle. Limites proposées : logo 2 Mo, produit 5 Mo ;

JPEG/PNG/WebP réencodés, métadonnées supprimées, noms aléatoires, variantes WebP/AVIF 320/640/960. SVG refusé au MVP.

7.3 Transaction, idempotence et concurrence

`create_public_order` reçoit jeton table, IDs produit, quantités, notes et UUID d'idempotence ; les prix reçus ne font jamais autorité. Dans une transaction, elle résout café/table, verrouille l'état pertinent, charge produits, calcule les lignes, écrit commande/items/historique et outbox. La contrainte unique `(cafe_id,idempotency_key)` transforme un retry en lecture du résultat existant.

Le suivi retourne référence et secret à haute entropie ; seul le hash demeure. Les transitions serveurs utilisent `WHERE id=? AND version=?` ; zéro ligne produit 409 et rechargement.

7.4 Realtime, push et reprise

Au premier plan, Realtime signale les changements autorisés ; l'app recharge les données canoniques et déduplique par `order_id + version`. À la reconnexion et à chaque reprise, elle requête les actives modifiées depuis son curseur, puis remplace le cache.

En arrière-plan ou fermée, un worker lit l'outbox après commit et envoie via Expo Push vers APNs/FCM. Tickets et receipts sont contrôlés ; `DeviceNotRegistered` désactive le jeton. Une permission refusée n'empêche ni l'usage ni Realtime et l'UI propose les réglages système. La notification verrouillée reste générique.

Frontière technique

Supabase Realtime ne constitue pas un service de push mobile lorsque l'OS suspend ou ferme l'application. L'outbox, le worker et APNs/FCM sont indispensables.

7.5 Journalisation, sauvegarde et reprise

Les logs structurés comportent request ID, fonction, résultat, latence et IDs techniques nécessaires, mais aucun jeton, note libre ou email complet. Les alertes couvrent erreurs de création, latence, retard d'outbox et échecs push. Sauvegardes Supabase selon l'offre, export chiffré périodique et test de restauration trimestriel sont recommandés. RPO 24 h et RTO 8 h sont des hypothèses à valider. La restauration s'effectue d'abord en environnement isolé, avec contrôles d'intégrité et d'isolation avant bascule.

Chapitre 8

Sécurité, confidentialité et fiabilité

8.1 Contrôles obligatoires

— isolation tenant sur tables, vues, RPC, canaux Realtime et chemins Storage ;
— fonctions administratives avec session, profil actif, rôle et audit ;
— création/suivi anonyme uniquement par fonctions dédiées et secrets opaques ;
— calcul serveur et contraintes SQL dans une transaction ;
— rate limit par IP hachée, table et café, quotas de lignes/notes, CAPTCHA adaptatif ;
— CSP stricte, HTTPS/HSTS, CSRF pour les cookies, rotation des secrets et dépendances surveillées ;
— notification générique sur écran verrouillé et détail après authentification ;
— aucune identité client demandée, avertissement contre les données sensibles dans les notes ;
— révocation des sessions et push tokens à la désactivation.

8.2 Menaces prioritaires

Table 8.1 – Menaces et vérifications

Menace	Mesure	Preuve attendue
Changer `cafe_id`	RLS dérive de l'identité	Tests croisés A/B.
Énumérer les commandes	Jeton haute entropie + rate limit	404 uniforme avec mauvais jeton.
Falsifier le prix	Prix ignoré, recalcul SQL	Requête modifiée sans effet.
Spam	QR actif, quota, rate limit, CAPTCHA adaptatif	Rafale bloquée, usage normal intact.
Double commande	Idempotence unique et transaction	Retries simultanés : même ID.
Fuite service role	Secret uniquement coffre/fonction	Scan dépôt et bundles.
Upload hostile	MIME réel, réencodage, taille, pas de SVG	Corpus de fichiers malveillants refusé.

Chapitre 9

UX, information et écrans

9.1 Architectures de navigation

Administration : Connexion → Cafés → Vue café (Aperçu, Identité, Menu, Tables et QR, Serveurs, Commandes, Publication). Niveau global : Toutes les commandes, Journal, Compte.

Client : Menu → Détail produit → Panier → Vérification → Confirmation et suivi.

Serveur : Connexion → Commandes actives → Détail/action ; onglets Actives, Historique, Compte.

Principes : ajout client en deux gestes maximum ; panier mobile collant ; une action principale par état serveur ; nouvelles commandes épinglées ; brouillon et publication séparés ; aucune action destructive sans confirmation ; tous les états chargement, vide, erreur, succès, offline et désactivé sont conçus.

9.2 Inventaire détaillé des écrans

Table 9.1 – Écrans de l'administration

ID	Écran / but	Hiérarchie et données	Actions, états et responsive
A01	Connexion admin	Marque plateforme, email, mot de passe, oubli, sécurité.	Erreur générique ; bouton chargé ; carte centrée.
A02	Cafés / tableau	KPI actives, liste logo/nom/statut/URL/publication, filtres.	Créer, ouvrir, suspendre ; cartes mobile, tableau desktop.
A03	Assistant café	Identité, contacts, devise/fuseau, marque, récapitulatif.	Étapes, validation, brouillon récupérable.
A04	Identité/marque	Formulaire gauche, aperçu droit, logo/couleurs/contacts.	Sauver, aperçu ; alerte contraste ; empilé tablette.
A05	Menu	Non-publié, catégories ordonnées, recherche, cartes produit.	Ajouter/éditer/ordonner, disponibilité immédiate.
A06	Produit	Photo 4 :3, nom, description, catégorie, prix, état.	Sauver brouillon, archiver confirmé, progression upload.
A07	Tables/QR	Libellé, état, rotation, actions, sélection.	Créer, PNG/PDF, régénérer/désactiver confirmés.
A08	Serveurs	Nom, email, statut, café, dernière activité.	Inviter, renvoyer, reset, désactiver ; jamais menu.
A09	Commandes	Filtres, référence, âge, total, statut, panneau détail.	Ouvrir/correction tracée, pagination serveur.

ID	Écran / but	Hiérarchie et données	Actions, états et responsive
A10	Publication	Checklist, changements, URL, suspension.	Publier atomiquement ; échec conserve brouillon.

Table 9.2 – Écrans du client public

ID	Écran / but	Hiérarchie et données	Actions, états et responsive
C01	Menu	Marque, table, catégories, cartes, panier collant.	Parcourir/ajouter ; sans table, envoi bloqué ; grille adaptative.
C02	Détail produit	Photo, nom, description, prix, disponibilité, quantité, note.	Feuille basse mobile, modale desktop, focus piégé.
C03	Panier	Table, lignes, contrôles, notes, total.	Modifier, supprimer, commander ; panier conservé sur erreur.
C04	Envoi	Résumé final, table, aucune identité obligatoire.	Envoi idempotent ; divergence prix/stock corrigeable.
C05	Suivi	Référence, statut textuel, chronologie, lignes, total.	Rafraîchir offline, retour menu ; jeton secret.
C06	Indisponible/QR	Message non technique et aide.	Voir menu général/ rescanner ; jamais commander.

Table 9.3 – Écrans de l’application serveur

ID	Écran / but	Hiérarchie et données	Actions, états et responsive
S01	Connexion	Email, mot de passe, oubli, état café post-auth.	Erreurs et désactivation ; aucune sélection café.
S02	Actives	Réseau, compteur, table, âge, état, résumé, note, total.	Ouvrir/accepter/filtrer ; 1 colonne mobile, 2 tablette.
S03	Détail	Référence/heure, lignes/notes, total, histoire.	Action suivante ; annulation avec motif ; conflit rechargé.
S04	Mise à jour	Confirmation intégrée ; feuille d’annulation.	Spinner local, double tap bloqué, succès serveur requis.
S05	Historique	Date, statut/table, pagination, terminaux.	Détail lecture seule et charger plus.
S06	Compte/notif.	Profil/café, permission OS, son/vibration, appareils.	Demander dans contexte, réglages système, logout.
S07	Offline	Bannière, dernière sync, cache lecture seule.	Aucune transition ; retry et resync automatique.

9.3 Wireframes annotés

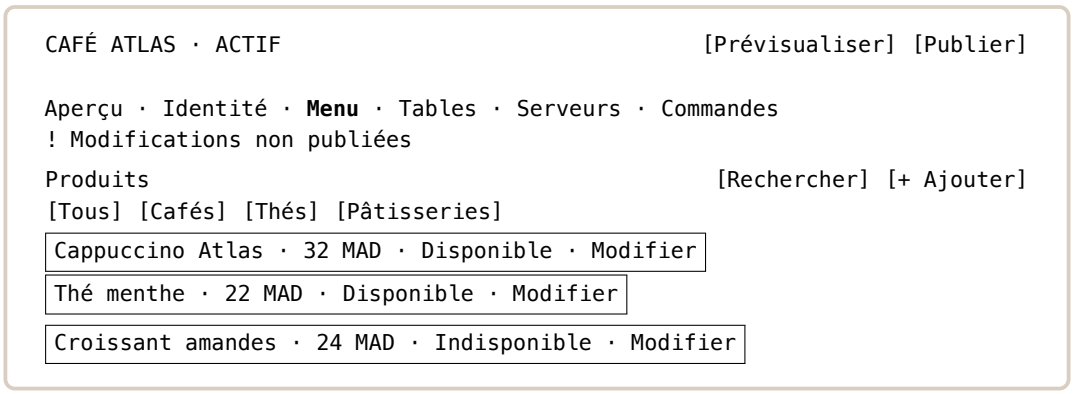


Figure 9.1 – Wireframe annoté A05 — gestion du menu

La bannière reste jusqu'à publication réussie ; les catégories filtrent sans mutation ; la disponibilité montre son résultat près du produit.

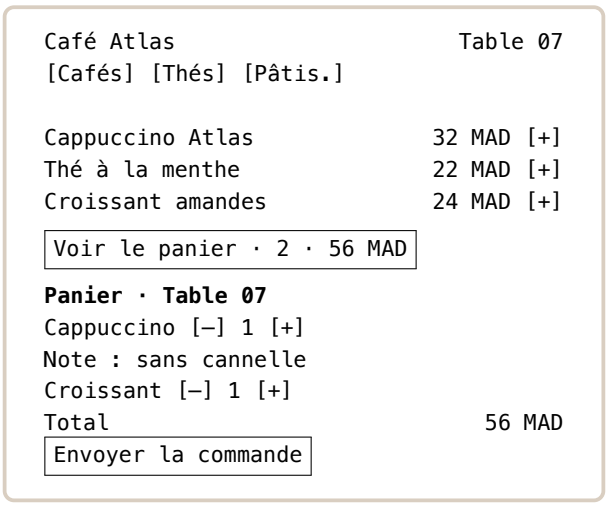


Figure 9.2 – Wireframe C01–C04 — menu et panier

Le contrôle panier est au-dessus de la zone système. L'envoi devient « Envoi… » et conserve la même clé d'idempotence sur retry.

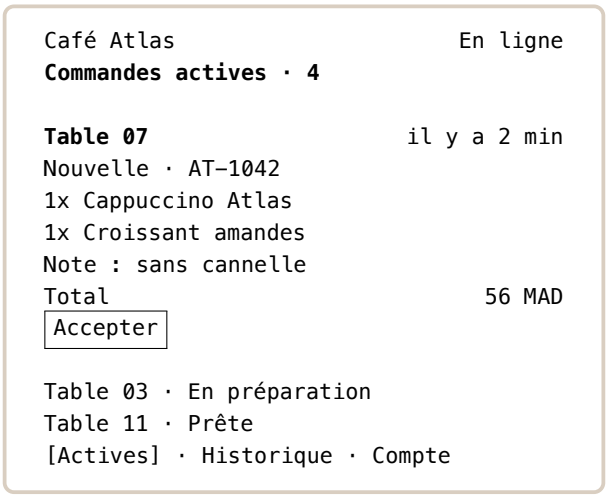


Figure 9.3 – Wireframe S02–S04 — traitement serveur

Les statuts combinent texte, icône dans l'implémentation et couleur. Un conflit remplace la carte par l'état canonique et explique l'action déjà effectuée.

9.4 Libellés et états

Chargement : « Chargement du menu… », « Synchronisation des commandes… ». Vide : « Aucun produit dans cette catégorie », « Aucune commande active — tout est à jour. » Erreur : « Impossible de charger. Vérifiez votre connexion et réessayez. » Succès : « Menu publié », « Commande AT-1042 acceptée ». Offline : « Connexion perdue — consultation possible, actions temporairement désactivées. » Validation : « Saisissez un prix supérieur ou égal à 0,00 MAD », « Image JPEG, PNG ou WebP, 5 Mo maximum ».

Chapitre 10

Design system visuel

10.1 Direction et couleurs

Le langage associe chaleur d'un café contemporain et efficacité opérationnelle. La plateforme reste neutre ; le site client reçoit les paramètres du café, sans modifier structure ni règles d'accessibilité.

Table 10.1 – Tokens de couleur

Token	HEX	Usage
brand.primary	`#8B5E3C`	Action Café Atlas, sélection.
brand.secondary	`#557A64`	Panier, action secondaire.
brand.accent	`#D98C32`	Prix et accent ponctuel.
background	`#FFFDF8`	Fond public crème.
background.neutral	`#F7F4EF`	Fond plateforme/mobile.
surface	`#FFFFFF`	Cartes et panneaux.
text	`#2B2118`	Texte principal.
text.muted	`#6D6259`	Texte secondaire contrôlé.
border	`#D9CEC1`	Contours.
success	`#247A4A`	Succès/prête avec icône+texte.
warning	`#A96509`	Attente/préparation.
error	`#B84444`	Erreur/destructif.
info	`#326A8A`	Information/synchronisation.
focus	`#1D70B8`	Anneau de focus 3 px.

Contraste : 4,5 :1 pour texte normal, 3 :1 pour grand texte et composants. Le moteur choisit texte blanc ou foncé sur la couleur café ; si aucun couple ne convient, il dérive une nuance accessible et avertit l'administrateur. La couleur ne porte jamais seule un statut.

10.2 Typographie, espace et grille

Titres marque/public : Fraunces 700, repli Georgia ; interface : Inter, system-ui, Segoe UI. Échelle : Display 40/48 (mobile 32/40), H1 32/40 (mobile 28/36), H2 24/32, H3 20/28, corps 16/24, petit

14/20, libellé 14/20 en 600, légende 12/16. Chiffres tabulaires pour prix et tables.

Espacements : 0, 4, 8, 12, 16, 24, 32, 48, 64, 96 px. Rayons : 6 champs, 10 boutons, 16 cartes, 24 feuilles, pilule 999. Ombres : légère `0 1px 3px rgba(43,33,24,.10)`, moyenne `0 8px 24px rgba(43,33,24,.12)`. Breakpoints : 600, 900 et 1200 px. Admin en 12 colonnes, contenu 1440 px, navigation 248 px ; public en 1/2/3–4 colonnes ; serveur une colonne mobile.

Images produit 4 :3, recadrage cover, point focal, tailles 320/640/960 ; fallback crème + pictogramme + nom accessible. Icônes linéaires 2 px en 20/24 px et libellé pour action ambiguë.

10.3 Accessibilité, mouvement et composants

Cibles au moins 44×44 px, ordre de focus visuel, Escape ferme les modales et restitue le focus, piège de focus, erreurs via `aria-describedby`, résumé en tête, live region polie pour panier/statut. Anneau focus bleu 3 px, décalage 2 px. Transitions 120/180/240 ms, sans déplacement avec `prefers-reduced-motion`.

Table 10.3 – Catalogue de composants

Composant	Variantes	États obligatoires
Bouton	primaire, secondaire, tertiaire, danger, icône	repos, hover, focus, pressé, chargement, désactivé
Champ/sélecteur	texte, email, prix, note, recherche, liste	vide, rempli, focus, erreur, lecture seule, désactivé
Carte	standard, sélection, commande urgente	repos, hover web, focus, sélection, squelette
Carte produit	liste/grille ; disponible/indisponible	image/fallback, ajout, quantité, désactivé
Catégories	puces scrollables/onglets	actif, inactif, focus, overflow
Panier	moins, quantité, plus, supprimer	min/max, attente, erreur
Commande/badge	six états canoniques	âge, note, conflit, offline ; icône+texte+couleur
Tableau	tri, filtre, pagination, sélection	chargement, vide, erreur, résultats
Modale/tiroir	confirmation, destructive, panier, produit	focus piégé, attente, erreur, retour focus
Toast/bannière	succès, info, erreur, non publié, offline	persistant si critique, action facultative
Navigation	latérale, haute, basse mobile	actif, badge, focus, offline
Squelette/vide	carte, liste, détail, premier usage	stable, reduced motion, CTA pertinent

Chapitre 11

Mockups représentatifs

Les figures suivantes sont des artefacts de design statiques et non une application. Elles utilisent Café Atlas et les mêmes produits ; de légères approximations typographiques d'image ne remplacent pas les spécifications textuelles.

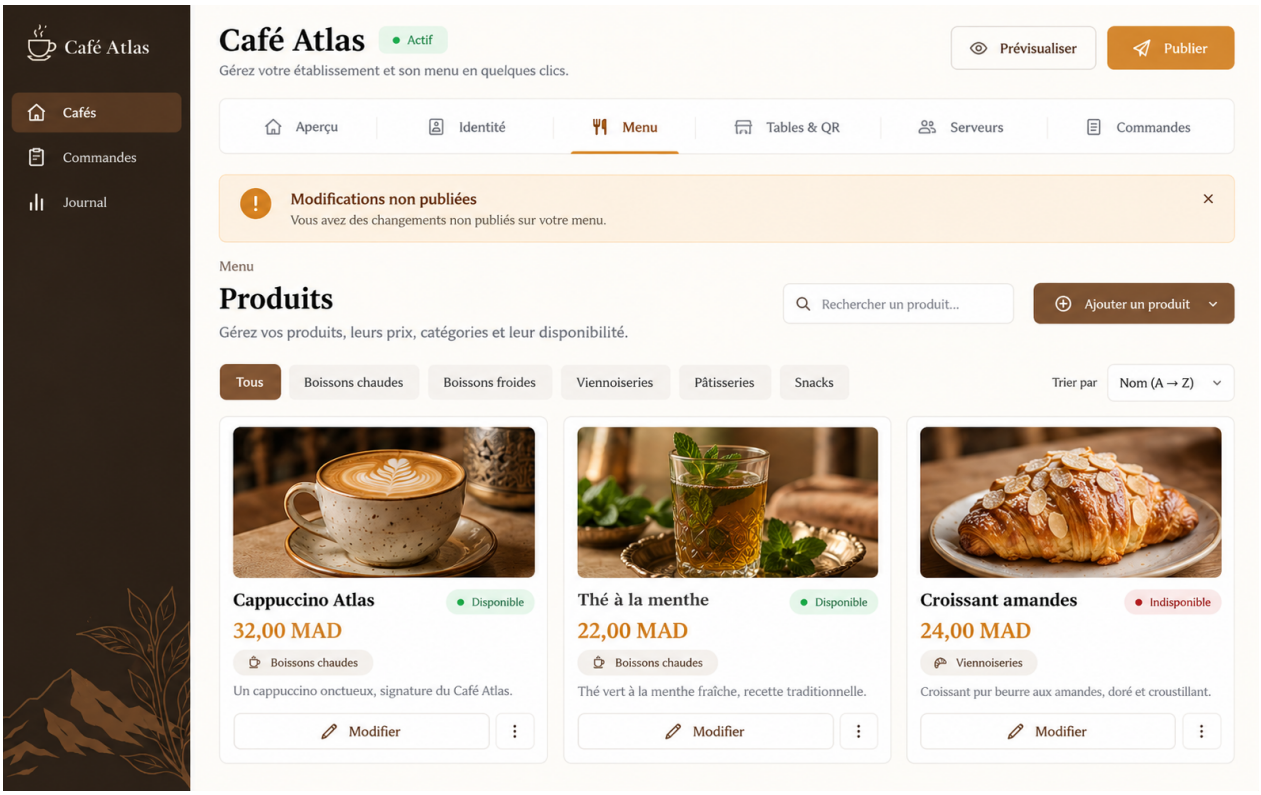


Figure 11.1 – Mockup haute fidélité — administration du menu Café Atlas

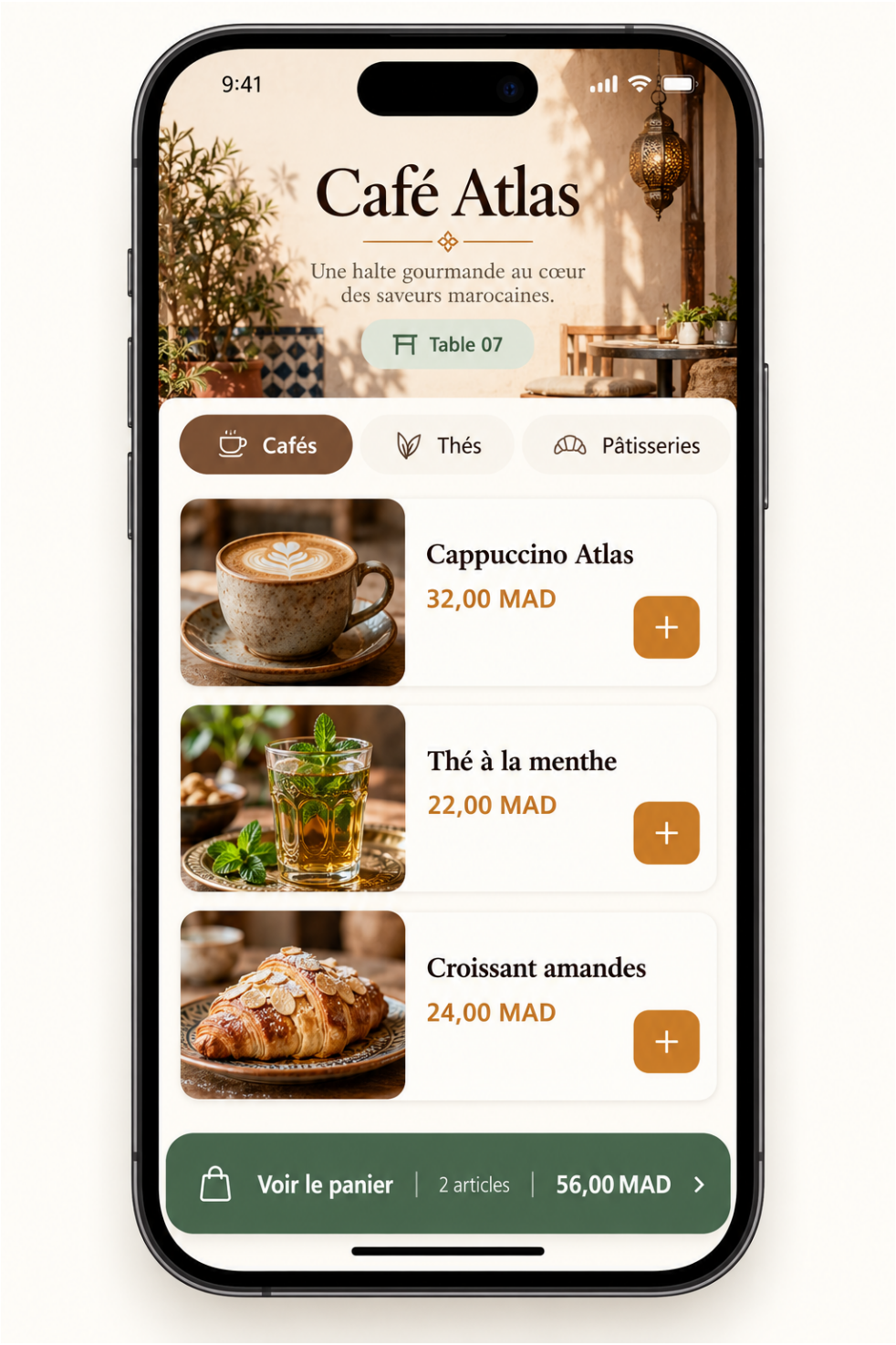


Figure 11.2 – Mockup haute fidélité — menu public mobile, Table 07

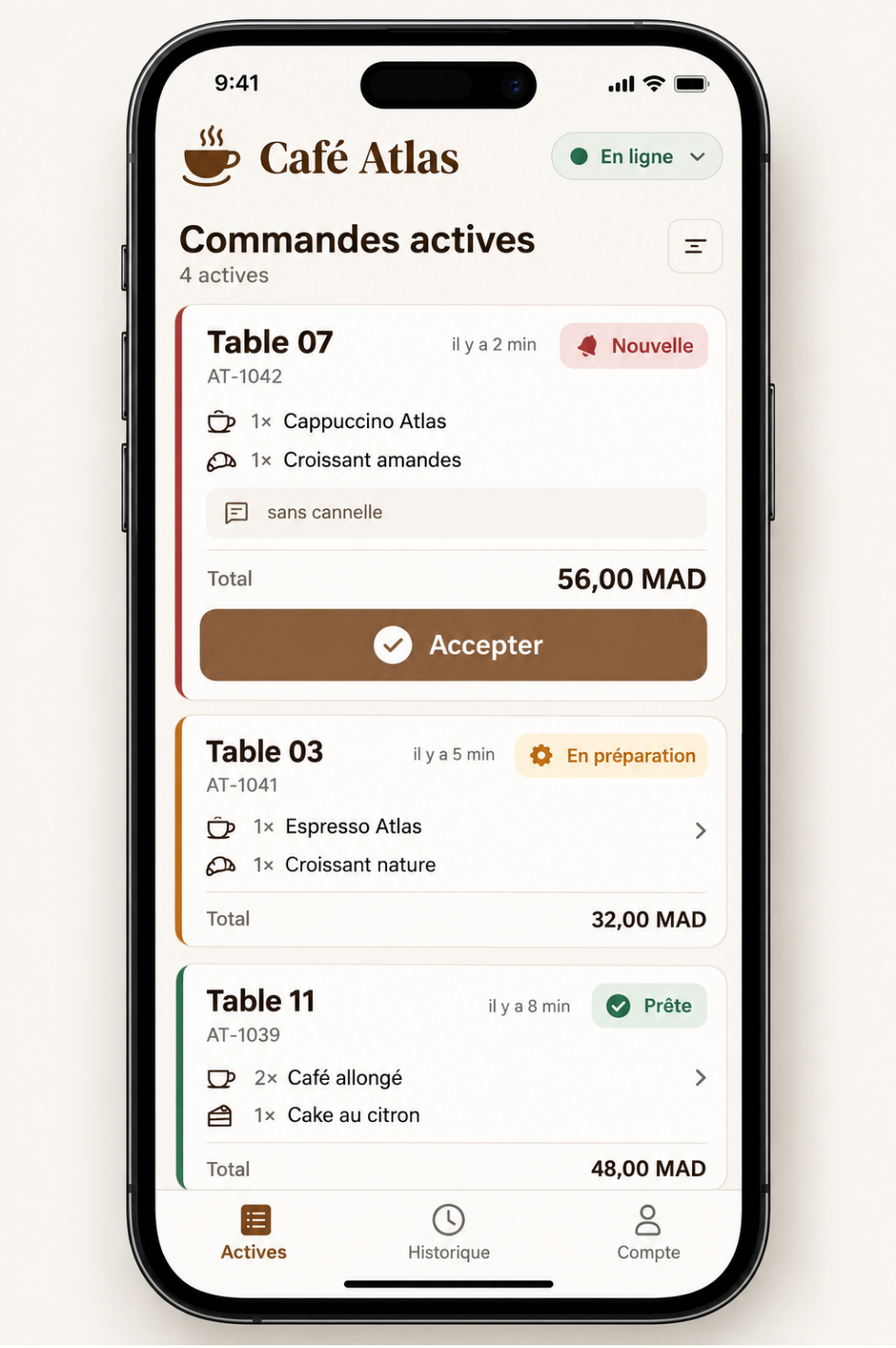


Figure 11.3 – Mockup haute fidélité — commandes actives du serveur

Chapitre 12

Tests et acceptation

12.1 Stratégie de vérification

Les tests unitaires couvrent calcul monétaire, transitions, validations, références et slugs. Les intégrations utilisent PostgreSQL/Supabase réels pour contraintes, transaction, RLS et Storage. Les E2E web couvrent admin, publication, QR, panier, suivi et suspension. Les E2E sur appareils réels couvrent Auth, Realtime, push, reprise, permissions et conflits. Les contrôles non fonctionnels couvrent responsive, clavier/lecteur d'écran, contraste, charge ciblée et restauration.

12.2 Scénarios Given / When / Then

Table 12.1 – Scénarios d'acceptation critiques

ID	Étant donné	Quand	Alors
AC-01	Admin authentifié.	Il crée Café Atlas avec slug unique.	Brouillon isolé, même projet, rien de public.
AC-02	Marque/menu valides.	Il publie.	Une version complète devient courante, cache/audit à jour.
AC-03	Produit publié.	Il devient indisponible.	Ajout et envoi refusés avec correction explicite.
AC-04	Jeton table renouvelé.	Ancien QR ouvert.	Menu éventuel, commande bloquée, nouveau jeton secret.
AC-05	Café/Table 07 actifs.	Client anonyme envoie deux produits.	Commande nouvelle, lignes figées, suivi sans compte.
AC-06	Produit à 32 MAD.	Requête prétend 1 MAD.	Serveur ignore et calcule 32 MAD.
AC-07	Panier à ancien prix.	Prix change avant envoi.	Aucun insert ; ancien/nouveau prix et reconfirmation.
AC-08	Réponse perdue après commit.	Retry avec même clé.	Même référence, une seule commande.
AC-09	Deux commandes anonymes.	Jeton mauvais/absent.	Aucune donnée, réponse uniforme.
AC-10	Serveur Café A.	Il se connecte.	Café dérivé du profil ; aucune donnée B.
AC-11	Commande nouvelle.	Actions permises successives.	Acceptée, préparation, prête, servie ; tout historisé.
AC-12	Commande nouvelle.	Tentative directe vers servie.	Refus, aucun historique ajouté.
AC-13	Deux serveurs lisent version 1.	Ils acceptent simultanément.	Un écrit v2, l'autre obtient 409 et l'état courant.

ID	Étant donné	Quand	Alors
AC-14	App ouverte et abonnée.	Commande créée.	Elle apparaît une fois et est relue sous RLS.
AC-15	Push autorisé, app fermée.	Commande créée.	Notification générique ; détail après authentification.
AC-16	Push refusé.	Serveur consulte les réglages.	État réel/lien OS ; Realtime fonctionne.
AC-17	App hors réseau.	Réseau revient.	Resync retrouve la commande sans événement.
AC-18	Café actif avec actives.	Admin suspend.	Nouvelles refusées, public informé, existantes clôturables.
AC-19	JWT Café A.	IDs Café B sur toutes opérations.	Zéro donnée ou refus uniforme.
AC-20	Serveur authentifié.	Appel admin/menu/branding/comptes.	403, aucun changement ni faux audit.
AC-21	Utilisateur clavier/lecteur.	Panier puis suivi.	Focus, erreurs, labels, annonces compréhensibles ; zéro critique.
AC-22	Sauvegarde de référence.	Restauration isolée.	Totaux, relations tenant, histoire et versions intègres.

Tester Chrome, Firefox, Safari et Edge récents, Safari iOS, Chrome Android ; largeurs 320, 390, 768, 1280 et 1440 px ; Android/iOS réels pour push. Simuler latence, offline, perte de réponse après commit, doublon Realtime, JWT expiré, token push invalide, panne Storage et fonctions indisponibles.

12.3 Checklist de sortie MVP

☐ Toutes les P0 ont un test traçable et vert.
☐ Zéro accès croisé Café A/B pour anon, serveur et rôle admin dégradé.
☐ Aucun secret privilégié dans le dépôt et les bundles.
☐ Six états et transitions identiques UI, API, DB et diagrammes.
☐ Double soumission : jamais deux commandes.
☐ Montants recalculés et instantanés stables.
☐ Realtime, push et resynchronisation testés séparément.
☐ Public sans compte et suivi seulement par jeton.
☐ Serveur sans écran ni droit menu.
☐ WCAG 2.2 AA des parcours essentiels vérifié manuellement et automatiquement.
☐ QR PDF/PNG imprimé puis scanné sur appareils réels.
☐ Suspension/réactivation et révocation validées.
☐ Sauvegarde/restauration et procédures d'incident testées.
☐ Monitoring et alertes opérationnels.

Chapitre 13

Feuille de route de livraison

Table 13.1 – Jalons, dépendances et risques

Jalon	Livrables	Dépendances	Acceptation	Risques
M0 Fondations	Monorepo, environnements, SQL, rôles/RLS, CI, tokens.	Décisions finales.	Tests isolation rouges puis verts.	RLS, schéma.
M1 Admin café/menu	Auth, cafés, marque, menu, Storage, aperçu.	M0.	Café Atlas sans code.	Publication, images.
M2 Publication/QR	Snapshot, public, tables, QR/rotation.	M1.	Menu mobile et bonne table.	Cache, QR copié.
M3 Commande	Panier, transaction, idempotence, suivi.	M2.	Prix/stock/réseau passent.	Spam, doublons.
M4 App serveur	Auth, actives, détail, histoire, Realtime.	M3.	Concurrence sans corruption.	Reconnexion.
M5 Push/exploitation	Outbox, Expo/APNs/FCM, monitoring, sauvegarde.	M4.	Ouvert/arrière-plan/fermé + rattrapage.	Certificats/tokens.
M6 Pilote MVP	Accessibilité, E2E, sécurité, runbooks, pilote.	M0–M5.	Checklist P0 et restauration.	Appareils, pointe.
Après MVP	Domaines, analytics, multi-affectation, exports.	Retour pilote.	Spécification séparée.	Complexité.

Aucune durée ou coût n'est avancé sans capacité d'équipe, niveau de service Supabase, contraintes stores et volume attendu.

Chapitre 14

Traçabilité et revue finale

Table 14.1 – Traçabilité des besoins majeurs

Besoin	Exigences	Écrans	Données / tests
Créer/publier café	ADM-002–007	A02–A06, A10	cafés, branding, versions ; AC-01/02
Menu et QR	ADM-005–008, PUB-001–004	A05–A07, C01	catégories, produits, tables ; AC-03/04
Commander sans compte	PUB-003–008	C01–C06	orders/items ; AC-05–09
Traiter au bon café	SRV-001–006	S01–S05	profils/histoire ; AC-10–13
Temps réel et push	SRV-002, 007–009	S02, S06/07	tokens/outbox ; AC-14–17
Suspension	ADM-011	A02/A10, C06	statut café ; AC-18
Isolation	Toutes	Toutes	RLS ; AC-19–22

La revue confirme : serveurs sans gestion menu, public sans compte, modèle public et Supabase partagés, six statuts identiques, push distinct de Realtime et aucune infrastructure notification omise.

14.1 Décisions restantes nécessitant validation

1. Confirmer le QR individuel par table et le blocage d'envoi sur l'URL générale.
2. Confirmer la devise par café, MAD pour Café Atlas, l'absence de taxes/frais et l'arrondi.
3. Décider si un produit indisponible reste visible avec badge ou est masqué.
4. Confirmer les acteurs/motifs d'annulation et la limite d'état.
5. Choisir le domaine final et valider la route `/slug` plutôt que les sous-domaines.
6. Confirmer Expo Push et les versions minimales Android/iOS.
7. Valider conservation, RPO/RTO et obligations juridiques locales.
8. Décider si une commande est autorisée hors horaires ; les horaires ne sont pas confirmés.

Chapitre A

Registre des sources et actifs

— Sources PlantUML : `docs/diagrams/01-contexte.puml` à `12-erd.puml`.
— Diagrammes PDF vectoriels : mêmes noms avec extension `.pdf`.
— Mockups PNG : `docs/mockups/01-administration-cafe-atlas.png`, `02-menu-public-mobile.png`, `03-commandes-serveur-mobile.png`.
— Spécifications Markdown : `docs/CAHIER_DES_CHARGES.md`, `DESIGN_SYSTEM.md`, `WIREFRAMES.md`, `ACCEPTATION.md`.